



RADICALLY OPEN SECURITY

Cryptographic Review

BAFTA Media Technology

V 0.2

Amsterdam, February 9th, 2026

Document Properties

Client	BAFTA Media Technology
Title	Cryptographic Review
Target	Paper
Version	0.2
Pentester	Younes Talibi Alaoui
Authors	Younes Talibi Alaoui, Marcus Bointon
Reviewed by	Marcus Bointon
Approved by	Melanie Rieback

Version control

Version	Date	Author	Description
0.1	February 1st, 2026	Younes Talibi Alaoui	Initial draft
0.2	February 9th, 2026	Marcus Bointon	Review

Contact

For more information about this document and its contents please contact Radically Open Security B.V.

Name	Melanie Rieback
Address	Science Park 608 1098 XH Amsterdam The Netherlands
Phone	+31 (0)20 2621 255
Email	info@radicallyopensecurity.com

Radically Open Security B.V. is registered at the trade register of the Dutch chamber of commerce under number 60628081.

Table of Contents

1	Executive Summary	4
1.1	Introduction	4
1.2	Scope of work	4
1.3	Summary of review	4
2	Overview of the protocol	5
2.1	Protocol Description	5
2.2	Related work	5
3	Technical Review	7
3.1	General Notes on the Paper	7
3.2	Threat Model and Cryptographic Security Guarantees	7
3.3	On Masking Using Random Offsets	8
3.4	Protocol Flow	8
3.5	Suggestions and Comparison with Other Protocols	8
4	Conclusion and recommendations	9
5	Bibliography	10
Appendix 1	Testing Team	11
Appendix 2	Paper	12

1 Executive Summary

1.1 Introduction

Between 28 October 2025 and 30 January 2026, we conducted a review of a paper describing a protocol developed by BAFTA Media Technology for a privacy-preserving system to collect and report sensitive diversity survey data.

The paper is attached in the appendix (the latest version of it).

1.2 Scope of work

The scope of work consisted of the following:

- A review of the system architecture, the primitives used, the protocol design, and the security guarantees (Sections 3 to 10): 2.5 days
- Comparison with related work, alternative approaches, and ideas to improve the protocol (Sections 12 and 13): 0.5 days
- Reporting: 0.5 days
- PM/Review: 0.5 days
- Total effort: 4 days

1.3 Summary of review

We provided comments primarily on the threat model, with the aim of clarifying the associated security guarantees. Additional comments addressed the description of the protocol. We also made recommendations to improve the protocol and included notes identifying potential directions for future work.

2 Overview of the protocol

The protocol addresses the challenge of collecting and reporting sensitive diversity survey data while preserving the privacy of respondents.

2.1 Protocol Description

At a high level description, the protocol involves four participants:

- Data Server
- Reporting Server
- Intersection Server
- Requesters

Each server holds its own cryptographic key for the Paillier encryption scheme, which supports homomorphic addition over ciphertexts (see Section 3 for details).

Requesters possess individual RSA key pairs used to sign reporting requests, ensuring that only authorized entities can submit queries to the system. In addition, each Requester holds a Paillier encryption key.

Survey responses are encrypted in two representations. The Expanded Bitfield representation is encrypted under the public key of the Reporting Server, while the Answer Index representation is encrypted under the public key of the Intersection Server (see Section 4 for details).

Two reporting scenarios are supported. The first scenario involves reporting on a single answer and relies on the Data Server and the Reporting Server, using only the Expanded Bitfield representation. The second scenario enables more complex reporting involving multiple answers per respondent and additionally involves the Intersection Server, using both the Expanded Bitfield and Answer Index representations. Further details are provided in Section 5.

Finally, the paper considers the application of differential privacy mechanisms, through the addition of noise at various stages of the reporting process, in order to mitigate potential information leakage from published results, in addition to other protective measures (see Sections 6 to 8 for more details).

2.2 Related work

Several works in the literature address privacy-preserving data collection and reporting; we mention the following three:

Prio [1] is a privacy-preserving aggregation system in which clients secret-share their inputs across multiple servers, which jointly compute aggregate statistics using MPC. To ensure robustness against malicious clients, Prio leverages secret-shared non-interactive proofs, combining MPC techniques with zero-knowledge proofs to provide correctness guarantees while revealing only aggregate results.

UnLynx [2] proposes a decentralized privacy-preserving data-sharing system based on additively homomorphic encryption, verifiable shuffling, and zero-knowledge proofs. Multiple servers jointly compute over encrypted data, support the collective addition of noise for differential privacy, and provide guarantees of confidentiality, unlinkability, and correctness without relying on a trusted central authority.

Finally, [3] studies privacy-preserving counting using fully homomorphic encryption, enabling computations directly over encrypted datasets. Given an encrypted dataset, the proposed techniques homomorphically evaluate a property function and produce encrypted counts of inputs sharing the same property, allowing statistics such as the number of records satisfying a given condition to be computed without decrypting individual data points.

3 Technical Review

3.1 General Notes on the Paper

The paper consists of a design document describing the protocol in detail.

The cryptographic primitives employed in the protocol are well-established, notably RSA and Paillier instantiated with sufficiently large key sizes to meet standard security requirements, and are appropriate for the stated security objectives (ensuring post-quantum security was out of scope in the paper). We did not identify any issues with their use in the context of the proposed system.

The mathematical constructions underlying the protocol, in particular those described in Section 5.2, provide a clear correctness argument for the encoding, padding, and processing of data, and we did not identify any inconsistencies or errors in this analysis.

The protocol's use of homomorphic properties is consistent with the theoretical guarantees of the underlying schemes, and the described computations correctly preserve correctness over encrypted data.

Finally, the planned integration of differential privacy mechanisms to mitigate potential information leakage from published aggregate results is well-motivated and appropriate. This approach correctly addresses a class of leakage that is not covered by cryptographic protections alone.

3.2 Threat Model and Cryptographic Security Guarantees

We provided comments on the threat model and the associated security guarantees, which have been addressed in the current version of the paper (attached). The updated document clearly states the assumptions under which the security analysis is conducted (specifically Section 9.1).

We note, however, that the security of the two reporting scenarios as described in the current version, can be aligned with formal cryptographic security proofs, as long as the adversary is only assumed to be semi-honest, in which case parties are assumed to follow the protocol correctly while attempting to infer additional information from their observations. In contrast, the document does not aim to provide security guarantees against malicious adversaries that may arbitrarily deviate from the protocol.

In particular, the reporting scenario involving only the Data Server and the Reporting Server closely matches a well-studied cryptographic architecture, in which one server performs homomorphic computations over encrypted data without access to the corresponding secret key, while another server holds the secret key and decrypts only the final aggregate result. Under a semi-honest adversary assumption, such architectures are commonly amenable to formal security proofs.

3.3 On Masking Using Random Offsets

In the reporting scenario involving the Intersection Server, random offsets are applied to ciphertexts prior to decryption by the Intersection Server. These offsets are currently applied to the Answer Index representation of the survey responses.

We recommend considering applying this masking directly to the Expanded Bitfield representation of the survey responses, to be able to get rid of the Answer Index representation of the responses, simplifying the protocol.

3.4 Protocol Flow

We provided some notes regarding the overall flow of the protocol to keep it consistent. These notes have been addressed in the current version.

3.5 Suggestions and Comparison with Other Protocols

As the paper already mentions, zero-knowledge proofs (ZKPs) could enhance the protocol's security properties. In addition to this, we also suggest considering active security (i.e., malicious adversaries) in future iterations of the protocol.

Additionally, we believe Fully Homomorphic Encryption (FHE) would be well-suited for this application, assuming the frequency of reporting requests is low and the resulting running times would be acceptable. If the logic expressions used for queries lead to circuits with low multiplicative depth, then FHE or even leveled homomorphic encryption could be viable options. This approach could potentially eliminate the need for the Intersection Server, simplifying the system architecture to a more common two-server arrangement.

4 Conclusion and recommendations

The paper presents a design document describing a well-structured protocol for the privacy-preserving collection and reporting of sensitive diversity survey data. Under the assumption of semi-honest adversaries, the cryptographic primitives and mathematical constructions employed are appropriate and correctly applied. In addition, the paper considers the inclusion of differential privacy mechanisms as a complementary layer of protection against information leakage from published aggregate results, addressing risks that are not covered by cryptographic techniques alone.

For future work, we recommend exploring the integration of zero-knowledge proofs to enhance verifiability, considering security against malicious adversaries, and evaluating fully homomorphic encryption as a potential approach to simplifying the system architecture.

5 Bibliography

- [1] *Prio: Private, Robust, and Scalable Computation of Aggregate Statistics.* . <https://arxiv.org/pdf/1703.06255>.
- [2] *UnLynx: A Decentralized System for Privacy-Conscious Data Sharing.* . <https://petsymposium.org/popets/2017/popets-2017-0047.pdf>.
- [3] *Homomorphically counting elements with the same property.* . <https://eprint.iacr.org/2025/1468.pdf>.

Appendix 1 Testing Team

Younes Talibi Alaoui (<i>pentester</i>)	Younes Talibi Alaoui received his PhD in cryptography from KU Leuven, with a focus on privacy-preserving technologies such as Multi-Party Computation. After his PhD, he started working as a cryptographer across companies.
Melanie Rieback (<i>approver</i>)	Melanie Rieback is a former Asst. Prof. of Computer Science from the VU, who is also the co-founder/CEO of Radically Open Security.

Appendix 2 Paper

The reviewed paper is provided as a separate attachment (document.pdf).

Front page image by Slava (<https://secure.flickr.com/photos/slava/496607907/>), "Mango HaX0ring",
Image styling by Patricia Piolon, <https://creativecommons.org/licenses/by-sa/2.0/legalcode>.